



中华人民共和国通信行业标准

YD/T [×××××]—[××××]

[代替 YD/T]

基础电信企业数据安全管理系统 技术要求

Technical requirements for data security management system of basic
telecommunication enterprises

(报批稿)

[××××]-[××]-[××]发布

[××××]-[××]-[××]实施

中华人民共和国工业和信息化部 发布

目 次

前 言.....V

1 范围.....1

2 规范性引用文件.....1

3 术语和定义.....1

4 缩略语.....2

5 数据安全管理系统架构.....2

6 监控管理系统功能要求.....4

6.1 指令管理.....4

6.1.1 指令配置.....4

6.1.1.1 指令配置概述.....4

6.1.1.2 指令创建.....4

6.1.1.3 指令变更.....4

6.1.1.4 指令失效.....4

6.1.2 指令审批.....4

6.1.3 指令下发.....4

6.2 数据展示.....5

6.2.1 安全态势展示.....5

6.2.2 安全态势分析和预警.....5

6.3 事件追踪处置.....5

6.4 基础管理.....5

6.4.1 用户管理.....5

6.4.1.1 账号管理.....5

6.4.1.2 身份认证.....5

6.4.1.3 权限管理.....6

6.4.1.4 远程管理.....6

6.4.2 日志管理.....6

6.4.2.1 日志记录.....6

6.4.2.2 安全审计.....6

6.4.3 交互接口管理.....6

6.4.4 备份恢复管理.....6

6.4.5 时间同步管理.....6

6.4.6 系统数据保护.....6

6.4.6.1 数据加密.....6

6.4.6.2 数据脱敏.....7

7 基础能力系统功能要求.....7

7.1 数据资产管理.....7

7.1.1 数据资产信息采集.....7

7.1.1.1 采集方式及范围.....7

7.1.1.2 采集策略管理.....7

7.1.1.3 采集任务管理.....7

7.1.2 数据资产信息存储.....7

7.1.3 数据资产识别.....8

7.1.3.1 数据内容识别.....8

7.1.3.2 数据分类分级.....8

7.1.3.3 数据资产清单管理.....8

7.1.4 数据资产分析.....8

7.2 访问和操作审计.....8

7.2.1 审计信息采集.....8

7.2.2 审计信息存储和查询.....8

7.2.3 审计分析.....9

7.2.3.1 协议分析.....9

7.2.3.2 审计策略.....9

7.2.3.3 会话和轨迹分析.....9

7.2.3.4 告警管理.....10

7.2.3.5 审计报表.....10

7.3 数据脱敏.....10

7.3.1 数据梳理和识别.....10

7.3.2 数据脱敏模式.....10

7.3.2.1 集中审批模式.....10

7.3.2.2 隔离模式.....10

7.3.2.3 实时模式.....10

7.3.3 数据脱敏策略.....11

7.3.3.1 数据源过滤.....11

7.3.3.2 数据脱敏策略.....11

7.3.3.3 数据脱敏任务管理.....11

7.3.3.4 数据对比.....11

7.3.3.5 集群脱敏.....11

7.3.4 数据源支持能力.....11

7.4 数据溯源.....11

7.4.1 数据溯源策略.....11

7.4.2 数据源支持能力.....12

7.5 数据加密.....12

7.5.1 数据加密管理.....12

7.5.1.1 基础加密管理.....12

7.5.1.2 动态表加密.....12

7.5.1.3 增强权限控制.....12

7.5.2 加密密钥管理.....12

7.5.2.1 分级密钥管理.....	12
7.5.2.2 密钥更新管理.....	12
7.5.3 数据加密任务管理.....	12
7.6 应用流量安全.....	12
7.6.1 应用流量数据采集.....	12
7.6.2 应用流量数据存储.....	13
7.6.3 数据流动分析.....	13
7.6.3.1 数据流转分析.....	13
7.6.3.2 用户行为分析.....	13
7.6.3.3 数据泄露风险分析.....	13
7.6.3.4 违规操作风险分析.....	13
7.6.3.5 数据流动关联分析与预警推送.....	13
7.7 数据接口安全.....	13
7.7.1 数据开放接口管理.....	14
7.7.2 数据对外开放管理.....	14
7.8 集中管控与数据展示.....	14
7.8.1 策略管控.....	14
7.8.2 安全态势展示.....	14
7.8.3 安全态势分析和预警.....	14
7.8.3.1 数据资产分析.....	14
7.8.3.2 分类分级分析.....	15
7.8.3.3 数据热度分析.....	15
7.8.3.4 数据流向分析.....	15
7.8.3.5 数据风险分析.....	15
7.8.3.6 用户行为分析.....	15
7.8.3.7 安全风险模型与告警.....	15
7.9 事件追踪处置.....	15
7.10 数据上报与指令接收.....	15
7.10.1 数据上报.....	16
7.10.1.1 数据上报要求.....	16
7.10.1.2 数据资产情况上报.....	16
7.10.1.3 数据对外共享情况上报.....	16
7.10.1.4 敏感数据脱敏处理情况上报.....	16
7.10.1.5 数据安全事件上报.....	16
7.10.2 指令接收.....	16
7.11 基础管理.....	16
7.11.1 用户管理.....	16
7.11.2 日志管理.....	16
7.11.3 交互接口管理.....	16
7.11.3.1 一类接口管理.....	16
7.11.3.2 二类接口管理.....	16
7.11.4 备份恢复管理.....	17

7.11.5 时间同步管理.....17

7.11.6 系统数据保护.....17

附 录 A （资料性） 数据安全管理系统部署示例.....18

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》给出的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别这些专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、中国移动通信集团有限公司、中国联合网络通信集团有限公司、中国电信集团有限公司、数据通信科学技术研究所、中安威士（北京）科技有限公司、华信咨询设计研究院有限公司、北京亚鸿世纪科技发展有限公司。

本文件主要起草人：郭建南、姜宇泽、江为强、王光涛、李文琦、和建文、孔令南、冯国栋、范楠、于文良、耿冠和、汪志、刘晓、戴林、崔宗军、邱云翔、黄莹、丁沛、成海、刘为华。

基础电信企业数据安全管理系统技术要求

1 范围

本文件规定了基础电信企业数据安全管理系统技术要求，包括数据安全管理系统架构、监控管理系统功能要求和基础能力系统功能要求。在监控管理系统层面提出指令管理、数据展示、事件追踪处置、基础管理等功能的技术要求，在基础能力系统层面提出数据资产管理、访问和操作审计、数据脱敏、数据溯源、数据加密、应用流量安全、数据接口安全、集中管控与数据展示、事件追踪处置、数据上报与指令接收、基础管理等功能的技术要求。

本文件适用于基础电信企业数据安全管理系统的设计、研发、实施、测评和验收等工作。企业可依据本规范开展数据安全管理系统建设或数据安全单点能力建设，提升企业数据安全风险监测和防护能力。

2 规范性引用文件

下列文件中的内容通过文中的规范性引用而构成本文件必不可少的条款。其中，注日期的引用文件，仅该日期对应的版本适用于本文件；不注日期的引用文件，其最新版本(包括所有的修改单)适用于本文件。

GB/T 25069	信息安全技术 术语
GB/T 29246-2017	信息安全技术 信息安全管理体系概述和词汇
GB/T 35273-2020	信息安全技术 个人信息安全规范
YD/T 3802-2020	电信网和互联网数据安全通用要求
YD/T 3813-2020	基础电信企业数据分类分级方法

3 术语和定义

GB/T 25069和GB/T 29246-2017界定的以及下列术语和定义适用于本文件。

3.1

数据安全管理系统 data security management system

具备数据资产管理、访问和操作审计、数据脱敏、数据加密、应用流量安全、数据接口安全等能力的统一管控系统，能够实现各类数据安全策略的集中化管理和数据安全风险的统一管控，并提供数据资产分布态势、数据使用态势、数据流动态势、流量监控态势、用户行为态势、风险分布态势分析等数据展示，以及数据安全事件追踪处置管控能力。

3.2

数据资产 data assets

以电子形式记录的组织机构所拥有和控制的数据。

3.3

去标识化 de-identification

通过对个人信息的技术处理，使其在不借助额外信息的情况下，无法识别个人信息主体的过程。

注：去标识化建立在个体基础之上，保留了个体颗粒度，采用假名、加密、哈希函数等技术手段替代对个人信息的标识。

3.4

数据脱敏 data masking

对某些敏感信息通过一定规则进行数据的变形，实现敏感隐私数据的可靠保护。

4 缩略语

下列缩略语适用于本文件。

API	应用程序接口	Application Programming Interface
APT	高级持续威胁	Advanced Persistent Threat
FTP	文件传输协议	File Transfer Protocol
HTTP	超文本传输协议	Hypertext Transfer Protocol
IP	互联网协议	Internet Protocol
MAC	媒体访问控制	Media Access Control
NTP	网络时间协议	Network Time Protocol
VPN	虚拟专用网	Virtual Private Network

5 数据安全管理系统架构

数据安全管理系统功能架构可划分为监控管理系统和基础能力系统的双层架构，系统功能架构如图 1 所示。企业可结合自身组织架构划分情况，构建集团与子公司联动的双层架构系统，或构建单层架构系统，以提升企业数据安全能力。



图 1 数据安全管理系统功能架构图

图1中，监控管理系统采用集中建设部署方式，适用于基础电信企业集团公司部署，基础能力系统适用于省级基础电信企业及相关专业公司建设部署（数据安全管理系统双层架构部署示例参见附录A）。针对基础能力系统，企业可根据图1给出的功能架构建设部署数据安全管理系统；如企业已具备部分安全能力，可针对尚未具备的能力进行建设部署，已具备的能力可将分析、处置等结果数据和原始信息传送到数据安全管理系统集中管控和态势分析模块，以便实现企业级数据安全风险分析和态势呈现。如企业组织架构仅包含单层架构，可采用单层数据安全管理系统架构部署方案（数据安全管理系统单层架构部署示例参见附录A）。单层架构的数据安全管理系统中，应用层包括数据资产管理、访问和操作审计、数据脱敏、数据溯源、数据加密、应用流量安全、数据接口安全、事件跟踪处置；展示层包括集中管控、数据展示（安全态势展示、安全态势分析和预警）；基础管理包括用户管理、日志管理、交互接口管理（二类接口管理）、备份恢复管理、时间同步管理、系统数据保护。

数据安全管理系统涉及两类交互接口：

- a) 一类接口指监控管理系统与基础能力系统间交互的接口，包括数据上报接口和指令下发接口。数据上报接口指基础能力系统向监控管理系统进行数据上报的接口，指令接收接口指监控管理系统向基础能力系统下发指令的接口。监控管理系统负责一类接口规范制定，基础能力系统按照接口规范配置其一类接口参数，实现与监控管理系统的接口对接。
- b) 二类接口指基础能力系统与企业内其他系统间数据交互的接口，用于获取如网络流量、日志、数据等信息。

6 监控管理系统功能要求

6.1 指令管理

6.1.1 指令配置

6.1.1.1 指令配置概述

指令配置包括对本层数据展示策略的指令配置，以及对基础能力系统资产管理策略、访问和操作审计策略、数据脱敏策略、数据溯源策略、数据加密策略、应用流量安全策略、数据接口安全策略、集中管控与数据展示策略的指令配置。

6.1.1.2 指令创建

应支持以人工填写或文件导入方式实现指令创建。

应支持指令校验，校验内容包括不可命中、必然命中等。

应支持指令创建操作的日志记录功能，日志记录包括操作人员、操作时间、操作方式、指令编号、指令内容等。

6.1.1.3 指令变更

应支持以人工填写或文件导入方式实现指令变更。

应支持指令变更操作的日志记录功能，日志记录包括操作人员、操作时间、操作方式、指令编号、变更前指令内容、变更后指令内容等。

应支持屏蔽已失效指令的变更操作功能。

6.1.1.4 指令失效

应支持以人工填写或文件导入方式实现指令失效，应支持指令失效原因填写。

应支持指令失效操作的日志记录功能，日志记录包括操作人员、操作时间、操作方式、指令编号、指令内容等。

应支持失效指令的留存时间设置功能。

6.1.2 指令审批

应支持指令审批流程，能够通过多个角色的相互配合，实现指令创建、指令变更、指令失效、指令下发环节的多层级的指令审批，满足如下要求：

- a) 应支持审批流程设置和审批角色管理；
- b) 应支持审批进度查看，并通过站内消息、短信、邮件等方式对审批人员进行通知。

6.1.3 指令下发

应支持指令下发的配置功能，包括下发对象、下发方式（全量、逐条）、下发时间（立即、定时）等，提供指令下发结果查询，并通过站内消息、短信、邮件等方式对指令下发对象进行指令下发状态通知；针对下发失败行为，应提供原因记录和重试功能。

应支持指令下发日志记录功能，日志记录包括操作人员、操作时间、操作方式、指令编号、指令内容等。

6.2 数据展示

6.2.1 安全态势展示

应支持数据安全态势可视化展示功能，展示内容包括资产分布态势、数据使用态势、数据流动态势、流量监控态势、用户行为态势、风险分布态势等，并提供安全态势可视化展示的下钻功能，支持下钻查看各安全态势的详情与明细内容。

应支持自定义配置可视化内容的展示方式，包括地图、柱状图、饼图、环形图、仪表、面积图和雷达图等，支持通过配置地区IP段、组织架构进行不同地区和不同下属机构的态势展示。

6.2.2 安全态势分析和预警

分析和预警功能应满足如下要求：

- a) 数据态势分析：应支持对当前采集的各类数据等进行关联性分析，支持不同维度、不同层次、不同角度的统计分析能力；
- b) 风险模型管理：应支持内置风险事件模型，支持风险指标体系和风险模型配置功能，模型配置维度包含用户信息、数据操作行为、访问对象、访问事件和访问结果等；
- c) 安全态势分析：应支持多因子的关联识别能力，并根据资产所受威胁程度生成数据资产安全态势图；
- d) 安全告警：应支持对现存威胁事件、预知的安全风险等进行告警和预警，提供风险处置解决建议办法；应支持利用数据挖掘与融合技术处理历史数据和监测数据，经过安全态势评估与预测分析，对潜在安全风险进行分析预测，并输出预警信息。

6.3 事件追踪处置

应支持对系统告警和预警信息的追踪处置功能，对于监测发现的预警信息应跟踪处置结果，并形成处置记录，处置记录应包括：处置对象名称、处置方式和处置时间等。

6.4 基础管理

6.4.1 用户管理

6.4.1.1 账号管理

应支持账号实名制管理，如提供工号、手机号等实名信息绑定功能。

应支持口令长度、复杂度、有效期和更换周期策略配置和自动检查功能。

6.4.1.2 身份认证

应支持除口令鉴别以外的其他身份鉴别机制，至少包括以下一种：

- a) 电子签名或证书鉴别；
- b) 指纹鉴别、虹膜鉴别等生物鉴别方式；
- c) 图片验证、短信验证等验证码机制；

应支持认证失败策略配置功能，配置内容包括最大失败次数、锁定时间、解锁方式等。

应支持用户登录超时锁定或注销策略配置功能，配置内容包括最大超时时间、超时处置方式等。

6.4.1.3 权限管理

应支持用户角色划分功能，支持按照系统各功能模块细粒度的用户角色授权配置能力。

应支持创建子管理员并配置子管理员权限的功能。

6.4.1.4 远程管理

应支持远程管理策略配置，包括访问IP地址、端口、VPN认证方式等。

6.4.2 日志管理

6.4.2.1 日志记录

日志记录范围应覆盖所有用户访问和操作行为，以及系统运行、告警日志记录等。

- a) 日志记录内容应包括：时间、事件主体、事件客体、事件描述等。
- b) 应支持日志记录留存时间配置功能。
- c) 应支持日志记录完整性保护功能。

6.4.2.2 安全审计

审计范围应覆盖所有用户访问和操作日志记录。

应支持生成审计记录，审计记录内容应包括：事件时间、事件类型、事件主体身份、事件成功或失败等。

应支持审计记录完整性保护功能。

6.4.3 交互接口管理

应支持一类接口管理功能，满足如下要求：

- a) 应支持接口认证功能，可采用IP、MAC地址、账号口令、令牌等方式对请求访问接口的用户或系统进行身份认证；
- b) 应支持接口访问控制功能，支持对接口不安全输入参数进行限制或过滤能力，支持接口访问时间、访问频次等安全策略配置，能够对接口异常状态进行告警。

6.4.4 备份恢复管理

应支持备份恢复管理功能，支持对系统采集和产生数据的备份和恢复功能，提供自动化备份策略配置和备份文件恢复能力验证功能。

6.4.5 时间同步管理

应支持手工或NTP时间同步方式。

6.4.6 系统数据保护

6.4.6.1 数据加密

应支持数据加密能力，能够对传输和存储涉及的个人敏感信息及重要数据进行加密处理。

应支持安全传输协议，能够对登录认证、接口交互等数据传输通道进行保护。

6.4.6.2 数据脱敏

按照GB/T 35273-2020的规定，支持对个人信息前端展示的去标识化处理等措施。

7 基础能力系统功能要求

7.1 数据资产管理

7.1.1 数据资产信息采集

7.1.1.1 采集方式及范围

应采用数据源直连扫描、旁路协议解析、软件代理等方式实现数据的发现和采集，对不能自动发现的资产应支持通过接口、手动录入、批量导入等方式进行资产添加；应具备增量资产发现能力，能够根据数据表的变更情况或者新增视图等情况发现数据的变化，实施增量扫描。

数据资产采集范围应覆盖常见数据库、文件数据源、数据流量、数据集群，应满足如下要求：

- a) 常见数据库：应支持关系型数据库表结构化数据的扫描能力，以及非关系型数据库数据扫描能力，包括 Oracle、Db2、SQL Server、PostgreSQL、MySQL、MongoDB、Redis、Hive、HBase、星环 TDH、Impala 等；
- b) 文件数据源：应支持对文件服务系统、主机系统中文件的扫描能力，包括 CSV、XML、PDF、WORD、EXCEL 和 TXT 等文档，RAR、ZIP、GZ、7Z、GAR 等压缩文件（支持多层压缩解压），以及 SYSLOG 等日志文件进行采集；
- c) 数据流量：应支持 FTP、HTTP、TNS 等协议流量中数据的采集能力；
- d) 数据集群：应具备对疑似数据集群的检测与集群确认能力，能够对集群内的数据资产进行采集。

7.1.1.2 采集策略管理

应支持即时、定时、周期性在网数据资产扫描方式，能够及时发现新增资产，并提供扫描中断恢复机制。

应支持通过人工录入或文件导入的方式创建策略，能够对资产扫描的网段、端口范围、单一 IP 超时、服务类型、扫描方式等参数进行配置，提供采集策略的新建、修改、注销、查询等管理功能。

7.1.1.3 采集任务管理

采集任务管理包括采集任务配置、采集任务执行跟踪、采集任务查询、采集任务展示，应满足如下要求：

- a) 采集任务配置：单项任务应支持单条或批量策略导入功能；应支持对目标数据资产相关信息、任务执行方式、任务执行开始时间等关键参数的配置定义；
- b) 采集任务执行跟踪：应支持对任务执行状态的跟踪，能够实时查看任务执行比率以及任务成功或失败状态；
- c) 采集任务查询：应支持通过任务名称、目标IP、目标端口和目标数据资产名称等关键词进行任务查询，并支持任务详情查看功能；
- d) 采集任务展示：应支持任务执行列表展示，包括任务名称、任务状态、任务执行开始时间和任务执行结束时间等。

7.1.2 数据资产信息存储

应支持对采集与分析过程产生的结果数据的存储，存储信息包括元数据、数据分类分级标识、属主信息、采集过程信息、分析结果等。

7.1.3 数据资产识别

7.1.3.1 数据内容识别

应支持数据特征库管理功能，能够根据配置的数据特征自动识别数据内容。

7.1.3.2 数据分类分级

宜按照YD/T 3813-2020建立数据分类结构，并支持按照树状结构展示分类层级。

应支持数据分类分级策略配置功能，支持通过人工录入或文件导入的方式创建策略，支持对已录入策略的变更和查询功能。

应支持按照配置规则自动识别数据资产的分类和分级，并能够对个人敏感信息、重要数据进行标记。

7.1.3.3 数据资产清单管理

应支持基于数据资产采集和分析结果自动创建和更新数据资产清单的能力。

应支持数据资产清单展示功能，展示内容应包含：服务器IP、资源类型、是否涉敏、所属部门、所属业务系统和责任人等，并提供基于所属部门或业务系统的数据资产清单展示功能。

应支持数据资产清单编辑功能，能够对无法自动生成、错误的信息进行编辑，提供对数据资产认领功能，对无属主资产应能够通过系统告警提示等方式要求进行数据资产认领。

应支持数据资产清单的上报和共享功能。

7.1.4 数据资产分析

应支持数据的多维度属性分析，包括数据分布、数据分布差量、数据迁移信息、数据版权的识别与记录、数据潜在风险的识别、数据使用热度、数据资产威胁识别和数据资产可用性异常等；应支持对数据血缘关系的分析，能够形成数据血缘图谱。

7.2 访问和操作审计

7.2.1 审计信息采集

采集范围应包括各类数据库、应用的数据访问流量，支持通过镜像、探针等方式进行流量采集，针对探针方式，应支持加密传输协议。

应支持对采集节点的自动部署、统一配置、集中管理及监控，能够监控各个探针采集点的状态，当采集点无法正常发送日志信息时应进行告警，并提供异常状态自动修复能力。

应支持对采集信息的过滤，过滤参数包括数据库类型、数据库IP、端口和客户端IP等。

7.2.2 审计信息存储和查询

应支持数据访问日志流量清洗的能力。

应对采集的日志数据进行预处理，统一日志存储格式。日志存储内容应详尽显示访问行为发生的具体特征，日志内容包括访问时间、访问客户端IP、客户端MAC、客户端操作系统主机名、客户端操作系统用户名、客户端端口号、客户端连接工具名、数据库（数据源）用户名、数据库（数据源）IP、数据库（数据源）MAC、数据库（数据源）实例、表、列、操作类型、命令内容、结果内容、执

行时间、响应状态、影响行数、查询返回行、匹配的策略、风险等级等。

应支持对日志中的敏感信息去标识化处理能力。

应支持日志数据存储能力，提供日志留存时间配置功能；应支持日志数据的备份和还原，并提供远程备份和转储功能。

应支持指定范围的审计日志查询能力，应满足如下要求：

- a) 支持日志维度的独立或组合条件检索，可按照时间段、访问者、主机或数据库账号、被保护对象、访问命令、访问结果等维度及关键字进行精确或模糊匹配查询；
- b) 支持检索条件保存和复用；
- c) 支持检索结果导出功能，支持PDF、WORD和EXCEL等文件格式。

7.2.3 审计分析

7.2.3.1 协议分析

应支持通过监控网络端口自动发现未纳管数据库的能力。

应支持从流量中解析运维协议，包括TELNET、FTP、SSH、POP3、SMTP、IMAP、VNC等。

应支持从流量中解析出数据访问行为的能力，审计记录要求如下：

- a) 访问命令审计：应记录包括数据库实例名、数据库名、数据库用户、操作系统用户、主机名、数据库IP、数据库端口号、客户端IP、客户端端口号、数据库MAC地址、客户端MAC地址、客户端工具名称、SQL关键字、表、列、视图、触发器、存储过程、函数等多种数据对象、请求发生时间和SQL语句等；
- b) 访问结果审计：应记录SQL语句的执行时长及响应状态、SELECT语句的结果集、UPDATE/DELETE语句影响的行数和SELECT语句返回的行数等信息；
- c) 关联审计：应能够记录应用侧的用户操作，并具备将该操作与应用系统访问数据库行为关联的能力，应支持Tomcat、WebLogic、JBoss和WebSphere等中间件应用系统。

7.2.3.2 审计策略

应支持以下审计策略：

- a) 权限审计策略：应支持单维度和多维度的访问权限审计策略配置功能，包括客户端IP、客户端操作系统主机名、客户端操作系统用户名、数据库（数据源）用户名、表、列、操作类型、命令内容、响应状态、影响行数和查询返回行等；
- b) SQL攻击策略：应具有针对疑似SQL注入攻击行为特征的审计策略，出现疑似SQL注入攻击行为时能够进行告警；
- c) 风险策略：应具有针对危险性操作行为特征的审计策略，出现危险行为时能够及时告警；应支持对内置策略的启用、禁用和风险等级的调整等功能；
- d) 可信行为策略：应具有针对可信行为特征的审计策略，可配置主流数据库客户端可信行为策略的工具白名单。

在配置策略和条件检索时，应能够直接引用全局参数，全局参数包括客户端IP、客户端操作系统主机名、客户端操作系统用户名、数据库（数据源）用户名、表、列和SQL关键字等，并应支持全局参数的导入导出功能。

应支持对SQL关键字、表名和列名等的智能翻译。

7.2.3.3 会话和轨迹分析

应支持将审计记录重新组织为会话，并以会话为单位，展示多次数据访问的行为。

应支持以图形化方式直观展示访问来源、目标、操作的轨迹，能够通过轨迹定位到具体日志信息，并提供指定范围的日志过滤能力。

7.2.3.4 告警管理

告警管理应包括风险设置、误报处理、告警查询和告警外发，要求如下：

- a) 风险设置：应支持自定义告警风险等级，包括低风险、中风险、高风险三个等级；
- b) 告警处理：应支持以匹配的规则进行分类汇总，能够对告警事件进行处理，并记录处理结果；
- c) 告警查询：应支持告警日志的细粒度查询，包括数据源、事件类型和时间等；
- d) 告警外发：应支持将告警日志外发至第三方平台，外发格式包括 SYSLOG、API、SNMP、FTP、EMAIL 等。

7.2.3.5 审计报表

应支持对审计信息的多维分析结果进行展现，如图形、表格等展示类型。

审计报表内容应包括访问量分析、访问频率分析、访问来源分析、访问途径分析、访问的实例分析、操作行为分析、操作对象分析、操作条件分析和攻击行为分析等；应支持自定义审计报表功能，自定义参数包括分析维度、查询条件、模板等。

应支持定时审计报表生成任务功能，并提供审计报表结果外发和提醒功能。

7.3 数据脱敏

7.3.1 数据梳理和识别

应支持通过数据资产管理能力或者数据扫描功能自动识别数据源中存在的敏感数据信息，以批量方式梳理敏感数据，并提供敏感数据分布的可视化呈现。

数据脱敏功能模块宜内置丰富的敏感数据识别规则，并提供自定义敏感数据识别规则功能，包括正则表达式、数据字典、混合列和自定义函数等方式。

应支持按照数据的敏感等级设置统一的脱敏规则，再根据敏感数据类型设置统一的脱敏规则参数。

7.3.2 数据脱敏模式

7.3.2.1 集中审批模式

应支持基于脱敏流程的审批机制，实现跨部门的单一数据源使用申请、脱敏方案审核、脱敏任务审核、数据分发等任务。

应支持审批员角色设置，实现对关键配置的审核，关键配置包括脱敏规则、参数以及数据发布目标等。

7.3.2.2 隔离模式

应支持用户与数据资产绑定授权功能；应支持对虚拟环境上不同业务用户或租户访问数据进行数据脱敏的能力。

7.3.2.3 实时模式

应支持实时脱敏能力，能够对数据库通信协议进行解析、对SQL进行重写。

7.3.3 数据脱敏策略

7.3.3.1 数据源过滤

应支持单张表、跨数据表创建脱敏数据子集的能力，提供多种关键参数过滤条件，如数据分类、行数等。

7.3.3.2 数据脱敏策略

应支持自定义脱敏策略功能，能够根据不同数据使用场景设置数据脱敏规则。支持细粒度、多种不同算法组合的方式进行数据脱敏策略配置；脱敏规则应包括数据仿真、数据遮蔽、随机字符串、固定值、可逆脱敏、映射替换、随机替换、关联乱序、差分隐私等。

应支持通过数据子集、白名单等方式控制数据脱敏范围。

应支持在数据库和应用程序、运维工具之间的动态脱敏机制，可依据源IP、数据库账户等参数定义脱敏处理规则。

7.3.3.3 数据脱敏任务管理

应支持脱敏任务关键参数配置功能，关键参数包括抽取方式、抽取线程数、装载线程数和单次提交量等，脱敏任务应支持单次或周期运行等多种脱敏运行方式。

应支持脱敏任务记录功能，记录内容应包括运行时长、运行速度和数据量等。

7.3.3.4 数据对比

应提供数据脱敏效果对比查看功能。

7.3.3.5 集群脱敏

应支持集群脱敏方式，满足如下要求：

- a) 应支持集群各计算节点和控制节点注册与认证的集中配置管理；
- b) 支持根据负载情况，自动调整资源分配；
- c) 支持多任务并发脱敏模式。

7.3.4 数据源支持能力

应支持数据源直连或文件导入等方式进行脱敏，应支持常见数据库、文件数据源的数据脱敏，包括：

- a) Oracle、SQL Server、MySQL、MariaDB、Percona、OceanBase、Db2、Informix、Sybase ASE、达梦 DM、人大金仓 Kingbase、南大通用 GBase、神通 Oscar、华为 GaussDBA/T、巨杉 SequoiaDB、Teradata、PostgreSQL、Greenplum、Caché、MongoDB、SAP HANA、Elasticsearch、Redis、HBase、Hive、Impala、SparkSQL 等数据库；
- b) CSV、TXT、XML、JSON、DMP 和 EXCEL 等文件源。

7.4 数据溯源

7.4.1 数据溯源策略

按照 YD/T 3802-2020 的规定，支持数据溯源策略配置功能，能够根据不同数据使用场景设置数据水印规则。

应支持通过数据子集、白名单等方式控制数据水印范围。

应支持对单个或批量数据添加数据水印。

应支持数据水印执行记录功能，记录内容应包括运行时长、运行速度和数据量等。

7.4.2 数据源支持能力

应支持对数据内容、文本、图片、音频、视频等数据源的数据水印。

7.5 数据加密

7.5.1 数据加密管理

7.5.1.1 基础加密管理

应支持多种加密算法，包括 AES、SM4 等算法。

应支持对多种数据库加密的能力，包括 Oracle、MySQL 等数据库。应支持表空间和字段级数据加解密能力，支持加密表管理和表结构变更能力。

应支持密文索引技术，基于密文索引实现数据的相等、范围、模糊查询的能力，无需全文解密，保证对数据加密后功能不影响业务系统的正常运行。

7.5.1.2 动态表加密

应支持对定期归档、表结构相同的表进行自动、实时的加解密能力。

7.5.1.3 增强权限控制

应支持对加密表和字段的权限控制能力，访问控制应限定到指定时间和IP。

7.5.2 加密密钥管理

7.5.2.1 分级密钥管理

应支持密钥分级管理能力，主密钥和工作密钥应分离存储。

宜采用硬件密码模块对密钥进行保护。

7.5.2.2 密钥更新管理

应支持密钥自动或手动更新能力，自动更新周期可以设置为周、月、季度、年等。

7.5.3 数据加密任务管理

应支持加解密任务的管理能力，包括启动和暂停加解密任务，并提供任务描述、任务进度、任务开始时间和结束时间等信息的展示。

7.6 应用流量安全

7.6.1 应用流量数据采集

数据采集位置应覆盖企业内外网出入口，以及数据存储系统的网络汇聚层；数据采集方式应支持并联采集（镜像或分光）、串联采集或软件代理；采集数据源类型包括数据库流量、应用系统流量、文件访问流量等。

应支持从流量中还原出HTTP、SMTP、FTP、DNS等应用层协议，包括HTTP命令和结果、大数据平台访问命令和结果、文件请求和结果等；应支持对采集的数据进行预处理，包括格式统一、数据清洗、归并去重等。

7.6.2 应用流量数据存储

应支持结构化、半结构化、非结构化数据的存储能力，以及流量还原数据的存储能力。

应支持对已采集数据的快速检索能力，支持关键字、筛选条件的组合查询检索功能，支持数据检索条件的保存以及最近查询条件的自动记录能力。

应支持通过表格方式对搜索结果进行展示，以及分类统计结果的可视化。

7.6.3 数据流动分析

7.6.3.1 数据流转分析

应支持对网络流量整体情况进行检测分析，包括流量构成情况、数据流量分析、文件流转分析等。

应支持对网络流量中数据安全威胁事件进行检测及关联分析，包括数据资产权限变更类威胁、数据资产获取类威胁、数据资产可用性威胁、数据资产威胁信道、数据外泄隐秘信道等威胁检测。

应支持对数据访问行为进行监控，建立业务系统及用户的访问行为画像。

应支持对业务系统、用户的异常数据访问行为告警能力，包括对数据进行高频访问、有大量新用户或业务系统访问数据行为等。

7.6.3.2 用户行为分析

应支持使用用户画像、行为分析、数据指纹等技术构建不同元素的行为分析模型，实现个人行为分析和风险行为发现，风险行为包括非授权用户违规接入、账户盗用风险等。

7.6.3.3 数据泄露风险分析

应支持对数据资产分布节点进行检测分析。资产分布节点包括文件存储服务节点、认证服务节点、应用服务器节点、邮件服务器节点等；检测分析的文件格式包括压缩文件、PDF、文本文件、邮件、图片等。

应支持对数据资产所在网络流量异常事件进行检测，支持预设规则库、用户自定义规则等异常流量检测方法。

7.6.3.4 违规操作风险分析

应支持对违规操作风险场景进行监测和识别，包括使用账户进行越权访问、特权操作、账户共享等异常操作场景。远程越权访问监测包括对越权访问发现时间、操作权限名称、越权访问源地址、越权访问目的地址、越权访问应用等行为的监测；远程特权操作监测包括对密钥修改、账户共享、账户删除、关键数据修改等行为的监测；账户共享行为监测包括对账户共享方的账户信息、共享源/目的地址、共享时间等多维度信息的监测。

7.6.3.5 数据流动关联分析与预警推送

应支持企业全量操作日志及流量的关联分析，应支持数据流动安全威胁事件溯源分析能力，能够结合数据安全日志、安全设备日志、审计日志等日志信息，将数据安全风险与流量元数据进行关联分析，输出结果包括数据资产的流动路径、数据资产的风险路径、数据资产的威胁来源等溯源结果。

应支持通过站内信、短信、邮件、Syslog 等多渠道进行预警推送。

7.7 数据接口安全

7.7.1 数据开放接口管理

应支持 HTTP、FTP、SMTP 等开放接口管理分析功能，支持接口清单、接口使用情况、接口活跃度、接口敏感级别等统计与可视化展示的能力。

应支持基于通信行业数据分类分级标准、数据分级划分规则实现敏感数据的传输识别和监测。

7.7.2 数据对外开放管理

应支持不同场景下数据资产对外开放的管理能力，能够通过数据对外开放审批备案内容、数据资产分类分级结果及流量分析结果，监测数据对外合规开放及违规使用的情况，并记录数据对外开放行为日志。

应支持将数据报备信息与流量流转信息的匹配，能够限制对外开放合作的输出方式、数据使用者、数据范围、数据敏感级别和使用期限等内容，并能够结合接口审计、数据防泄露规则实现异常数据流转行为的监测识别。

7.8 集中管控与数据展示

7.8.1 策略管控

应支持对接入的安全功能能力模块进行统一集中管理，能够制定统一的标准平台接口和产品接入策略，并支持安全产品策略的统一管理与下发。

应支持日志统一管理，包含日志接入配置，汇总多源日志功能。

7.8.2 安全态势展示

应支持多维度的可视化展示能力，展示内容应包含以下维度：

- a) 资产分布态势：应支持展示数据资产分布概况，概况分析内容包括数据分类和分级分布情况、数据库分布情况、敏感数据库分布情况和数据量分布情况等；
- b) 数据流动态势：应支持通过动态的可视化展示，提供精准的体现数据资产的流动路径、数据资产访问周期、资产动态拓扑图、数据资产迁移情况；支持省市县级数据流动趋势、业务架构数据流动趋势、终端访问数据趋势和数据走向趋势等多维度数据流动态势展示。
- c) 用户访问态势：支持对用户的数据访问行为进行全面分析，从疑似恶意删除行为、疑似非法访问行为、疑似越权访问行为、疑似慢攻击行为、疑似拖库行为和疑似撞库等行为维度发现用户访问数据存在的风险，并支持通过可视化的方式展示用户访问数据的规律；
- d) 数据使用态势：支持通过数据被访问的操作行为与访问频率，分析数据资产使用热度、数据资产差量变化和数据库资产的访问风险等；
- e) 风险分布态势：支持从数据访问和操作行为、数据流动的路径等维度展示数据资产存在的风险情况，并通过内置的风险模型分析数据资产存在的潜在风险等。

7.8.3 安全态势分析和预警

7.8.3.1 数据资产分析

应支持对已注册的数据资产进行统计分析，并通过可视化的方式进行展示；

应支持数据资产分布图谱展示，能够按资产类型、库、表、列等维度进行资产下钻，支持基于

库、表、列、分级分类等多种维度可视化展示敏感数据分布情况、数据资产分布情况和数据操作情况等。

7.8.3.2 分类分级分析

支持对数据资产分类分级的可视化展示。应支持对非结构化数据、半结构化、结构化数据的独立展示；支持对数据存储系统、数据库类型、数据域和数据分类分级等维度的图形化展示。

7.8.3.3 数据热度分析

应根据数据资产活跃度提供数据热度可视化展示，提供高热资产 TopN 视图、低热资产 TopN 视图，以及高热、低热数据资产详细信息。

7.8.3.4 数据流向分析

应支持不同维度数据流量安全监测结果的分析及可视化展示，支持通过多种视图展示数据安全流量监测结果，支持对数据流向路径高亮展示及定位告警。

应支持至少三级以上的交互式可视能力，如依据数据安全流量监测结果可视、监测结果详细信息可视和安全管理控制策略下发可视等不同可视页面的展示与交互分析。

7.8.3.5 数据风险分析

应支持从时间、数据流动来源、数据流向范围、数据级别和数据安全事件等多维度进行筛选展示，能够通过不同颜色区分不同级别事件。

7.8.3.6 用户行为分析

应支持数据库用户操作日志的统计分析，能够识别用户操作数据资产的规律。支持用户数量、异常数量、操作总数、登录次数、登录使用的 MAC 地址个数和登录使用的 IP 地址个数等的统计功能；支持单个用户的操作总数、登录次数、在线状态、账号类型和首次登录时间等的统计功能；支持对用户的最近活跃情况进行分析，包括对活跃规律、活跃趋势、关联账号、风险类型、访问的数据资产等的分析。

7.8.3.7 安全风险模型与告警

应支持内置风险事件模型，以及自定义风险指标体系和风险模型配置功能，风险模型配置维度包含数据访问者信息、数据操作行为、访问对象、访问事件和访问结果等。

应支持通过内置的风险模型与配置的风险模型监控与感知风险，实时对数据资产自身潜在风险、内部数据操作行为风险和外部攻击等多重风险因素告警，并留存告警日志。

应支持触发告警后的及时响应，可对触发风险的目标用户或终端进行阻断。

应支持基于风险数量、风险等级和风险分布的统计、分析功能，提供风险预测能力。

7.9 事件追踪处置

应支持根据泄露数据信息进行数据溯源，能够定位数据泄露风险点，要求如下：

- 录入泄露数据：应支持通过人工输入或文件导入方式录入泄露数据；
- 提取敏感字段：应支持通过内置的敏感数据识别算法对录入的泄露数据进行匹配，提取其中的敏感数据类型；
- 选择溯源条件：应支持溯源条件配置功能，包括数据库用户、源 IP 地址、数据库名称、操作

类型和时间等。

7.10 数据上报与指令接收

7.10.1 数据上报

7.10.1.1 数据上报要求

企业侧策略运行情况上报内容应包括：数据资产管理、访问和操作行为审计、数据脱敏等模块的分析结果。

应支持多种上报接口和数据格式，接口包括WebService、RESTFUL技术，数据格式包括XML、JSON、CSV等。

7.10.1.2 数据资产情况上报

数据资产情况上报内容应包括：数据类型、数据分类、数据分级、数据资产位置信息等。

7.10.1.3 数据对外共享情况上报

数据对外共享情况上报内容应包括：共享数据源信息、共享数据目的信息、共享数据范围、共享数据分类、共享数据分级、数据共享方式等。

7.10.1.4 敏感数据脱敏处理情况上报

敏感数据脱敏处理情况上报内容应包括：脱敏场景、敏感数据范围、敏感数据分类、敏感数据分级、脱敏规则等。

7.10.1.5 数据安全事件上报

数据安全事件情报内容应包括：事件发生时间、事件类型、事件描述等。

7.10.2 指令接收

应支持监控管理系统下发指令的接收功能，指令接收内容应包括：指令类别、指令内容、指令接收反馈等。

7.11 基础管理

7.11.1 用户管理

基础能力系统用户管理要求同6.4.1。

7.11.2 日志管理

基础能力系统日志管理要求同6.4.2。

7.11.3 交互接口管理

7.11.3.1 一类接口管理

应支持接口认证参数配置功能，可实现与监控管理系统的对接，具备接口状态监控与告警功能。

7.11.3.2 二类接口管理

应支持接口认证功能，可采用 IP、MAC 地址、账号口令、令牌等方式对请求访问接口的用户或系统进行身份认证。

应支持接口访问控制功能，支持对接口不安全输入参数进行限制或过滤能力，支持接口访问时间、访问频次等安全策略配置，能够对接口异常状态进行告警。

7.11.4 备份恢复管理

基础能力系统日志管理要求同6.4.4。

7.11.5 时间同步管理

基础能力系统日志管理要求同6.4.5。

7.11.6 系统数据保护

基 础 能 力 系 统 日 志 管 理 要 求 同 6.4.6 。

附 录 A
(资料性)
数据安全管理系统部署示例

数据安全管理系统双层架构部署示例实现如图A.1所示。监控管理系统采用集中建设部署方式，适用于基础电信企业集团公司部署，基础能力系统适用于省级基础电信企业及相关专业公司建设部署，通过内联网实现数据上报和指令下发。

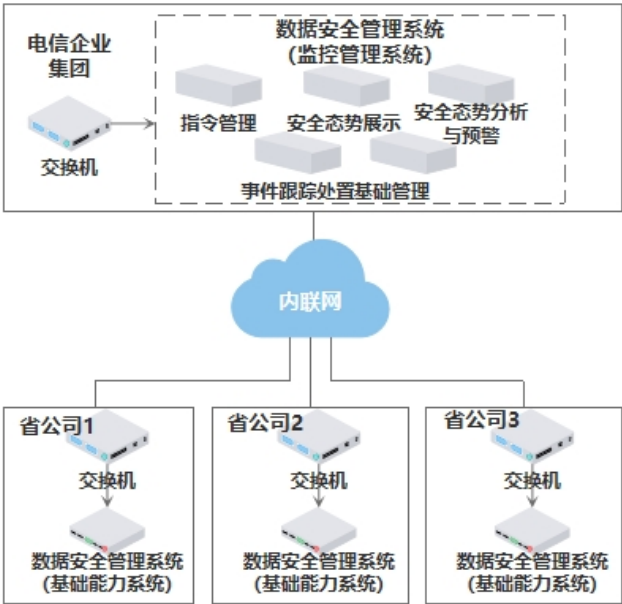


图 A.1 数据安全管理系统整体部署示例图

数据安全管理系统单层架构部署示例实现如图A.2所示。图中将安全能力分析、处置等结果数据和原始信息传送至数据安全管理系统（分控）的集中管控和态势分析模块中，实现各域分级管理和风险分析。各域数据安全管理中心将安全能力分析、处置等结果数据传送至数据安全管理系统（总控）中，以便实现企业级数据安全风险汇总分析和态势呈现。

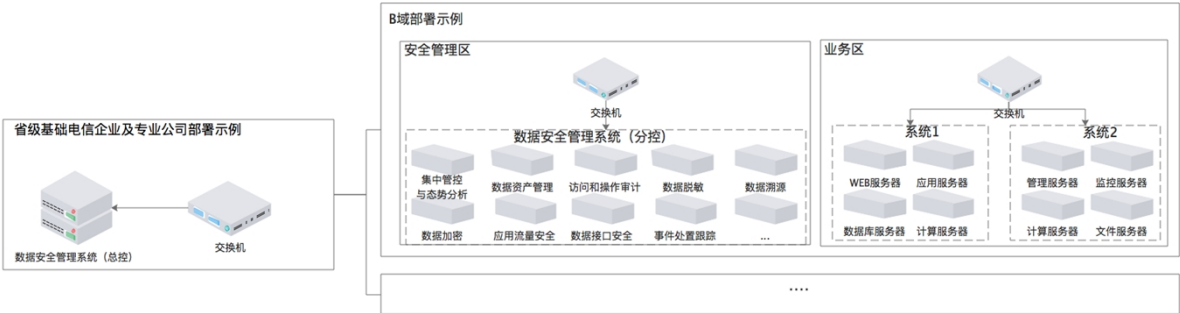


图 A.2 数据安全管理系统基础能力系统部署示例图